

1. Introduction

Phishing is one of the most common and effective forms of cyberattack used by threat actors to obtain sensitive information such as usernames, passwords, financial details, and one-time passwords (OTPs). These attacks typically rely on deceptive emails that appear to originate from trusted organizations, encouraging recipients to click malicious links, download infected attachments, or disclose confidential information.

The success of phishing attacks is largely driven by social engineering rather than technical vulnerabilities. Attackers exploit human trust, curiosity, and urgency to manipulate users into taking actions that compromise the security of individuals and organizations. As phishing techniques continue to evolve, user awareness and the ability to identify suspicious emails have become essential components of an organization's cybersecurity strategy.

This report presents a phishing detection and awareness assessment conducted using a controlled set of email samples. The analysis focuses on identifying phishing indicators, evaluating the legitimacy of email content, classifying the level of risk associated with each email, and providing practical recommendations to improve user awareness and reduce the likelihood of successful phishing attacks.

2. Objectives

The objectives of this project are to:

- Analyze phishing and legitimate email samples in a controlled environment.
- Identify common phishing indicators such as spoofed sender addresses, suspicious domains, malicious links, urgent language, and social engineering techniques.
- Classify each email as Safe, Suspicious, or Phishing based on the findings.
- Explain phishing techniques in clear, business-friendly language that can be understood by both technical and non-technical users.
- Develop prevention and awareness guidelines to help users recognize and respond appropriately to phishing attempts.
- Document the complete analysis in a structured report suitable for cybersecurity awareness and educational purposes.

3. Tools Used

The following tools and resources were used during this phishing detection and awareness project.

Tool	Purpose
Email Client (Gmail)	Sent and received email samples between personal accounts in a controlled environment.
Google Message Header Analyzer	Examined email headers and verified email authentication details where applicable.
MXToolbox Email Header Analyzer	Reviewed email header information and authentication results.
Web Browser	Safely inspected sender domains and hyperlinks without interacting with malicious content.
Microsoft Word / Google Docs / Canva	Prepared and formatted the final professional report.
GitHub	Hosted the report, supporting evidence, and project documentation in a public repository.

4. Methodology

The following methodology was followed to perform the phishing email detection and awareness analysis:

Step 1: Email Sample Collection

Three phishing email samples and one legitimate email sample were created for educational and analysis purposes. The emails were sent between two personal test email accounts to generate real email headers for examination.

Step 2: Email Header Extraction

The received emails were opened in Gmail, and the Show Original feature was used to extract the complete email headers. The headers were saved for further analysis.

Step 3: Header Analysis

Each email header was analyzed by examining the following fields:

- From
- Return-Path
- Reply-To
- SPF (Sender Policy Framework)
- DKIM (DomainKeys Identified Mail)
- DMARC (Domain-based Message Authentication, Reporting and Conformance)
- Received Chain

The authentication results were reviewed to determine whether the sender domain was properly authenticated.

Step 4: Sender Domain and Link Inspection

The sender's email address was compared with the official domain of the organization it claimed to represent. Any embedded hyperlinks were also inspected to determine whether they redirected users to legitimate or suspicious websites.

Step 5: Identification of Phishing Indicators

Each email was reviewed for common phishing characteristics, including:

- Spoofed or unofficial sender domains
- Generic greetings
- Urgent or threatening language
- Requests for sensitive information
- Suspicious hyperlinks
- Unexpected attachments
- Spelling or grammatical errors
- Attempts to impersonate trusted organizations

Step 6: Risk Classification

Based on the findings, each email was assigned a risk level:

- Legitimate
- Low Risk
- Medium Risk
- High Risk
- Critical Risk

The classification considered both the email content and the potential impact if a recipient interacted with the email.

Step 7: Documentation of Findings

The analysis results were documented in a structured report containing:

- Email screenshots
- Header analysis
- Sender domain verification
- Authentication results
- Phishing indicators
- Risk assessment
- Observations and recommendations

Step 8: Development of Prevention and Awareness Guidelines

Finally, security recommendations and phishing awareness guidelines were prepared to educate users on recognizing phishing attempts, safely handling suspicious emails, and reporting potential phishing attacks.

5. Phishing Email Samples

Sample 1:

Dear User,

We have detected unusual login activity on your cloud storage account from an unknown location.

To prevent temporary suspension, please verify your account immediately by clicking the link below:

<https://drive-account-verify.com/login>

If you do not verify your account within the next 12 hours, your files may become inaccessible.

Thank you,

Cloud Security Team

 Reply

 Forward



MessageId	CABwVR+2yc0UawvciO=0Gc4zY=2fiQkKX6YTTxBShASQ76qE8uw@mail.gmail.com
Created at:	7/7/2026, 3:45:00 PM GMT+5:30 (Delivered after 12 sec)
From:	Shlok Chavan <gajvakraresidency@gmail.com>
To:	[REDACTED]@gmail.com
Subject:	Payroll Information Update Required
DKIM:	pass with domain gmail.com Learn more

#	Delay	From *	To *	Protocol	Time received
0	11 sec		→ 2002:a05:6122:e46a:b0:5bd:4143:6a8a	SMTP	7/7/2026, 3:45:11 PM GMT+5:30
1	1 sec	mail-sor-f65.google.com.	→ [Google] mx.google.com		7/7/2026, 3:45:12 PM GMT+5:30 <i>Originated at Gmail</i>
2			→ [Google] 2002:a05:6122:3b8d:b0:5bd:c6ff:b6e5	SMTP	7/7/2026, 3:45:12 PM GMT+5:30
3			→ [Google] 2002:a8a:fa3:0:b0:63c:1f3b:a0fa	SMTP	7/7/2026, 3:45:12 PM GMT+5:30

Sample 2:

Payroll Information Update Required Inbox x



Shlok Chavan <gajvakraresedency@gmail.com>

to me ▾

Dear Employee,

During our monthly payroll review, we found incomplete information in your employee profile.

Please update your payroll details by accessing the secure employee portal below:

<https://employee-payroll-update.net>

Failure to complete the update before today may delay your salary payment.

Human Resources Department

↩ Reply

➦ Forward



Sample 3:

← ⓘ ⓘ ⓘ | ✉ 📁 ⋮

2 of 555 < >

Delivery Attempt Failed – Confirm Your Address Inbox x



Shlok Chavan <gajvakraresedency@gmail.com>
to me ▾

15:45 (11 minutes ago) ☆ 😊 ↩ ⋮

Dear Customer,

We attempted to deliver your package today, but the delivery could not be completed due to an incorrect shipping address.

Please confirm your address by visiting the link below:

<https://parcel-address-confirmation.com>

Your package will be returned to the sender if no action is taken within 24 hours.

Thank

↩ Reply

➦ Forward



MessageId	CABwVR+2LTRYghkZcai3jWeZny3aoUtmfBVe6SY74mCR1trVAHQ@mail.gmail.com
Created at:	7/7/2026, 3:45:25 PM GMT+5:30 (Delivered after 13 sec)
From:	Shlok Chavan <gajvakraresedency@gmail.com>
To:	XXXXXXXXXXXX@gmail.com
Subject:	Delivery Attempt Failed – Confirm Your Address
DKIM:	pass with domain gmail.com Learn more

#	Delay	From *	To *	Protocol	Time received
0	12 sec		→ 2002:a05:6123:5ce:20b0:5bd:b5ce:23ba	SMTP	7/7/2026, 3:45:37 PM GMT+5:30
1	1 sec	mail-sor-f65.google.com.	→ [Google] mx.google.com		7/7/2026, 3:45:38 PM GMT+5:30 <i>Originated at Gmail</i>
2			→ [Google] 2002:a05:6122:8b0a:b0:575:634a:a604	SMTP	7/7/2026, 3:45:38 PM GMT+5:30
3			→ [Google] 2002:a8a:fa3:0:b0:63c:1f3b:a0fa	SMTP	7/7/2026, 3:45:38 PM GMT+5:30

Sample 4:

Project Status Meeting Scheduled for Sunday

Inbox x



Shlok Chavan <gajvakraresedency@gmail.com>

to me ▾

15:46 (4 hours ago) ☆

Dear Team,

This is a reminder that our weekly project status meeting is scheduled for **Sunday, July 11, at 10:00 AM** in Meeting Room 2.

During the meeting, we will review project progress, discuss pending tasks, and plan activities for the upcoming week.

Please bring your project updates and notify your team lead if you are unable to attend.

The meeting agenda has been attached for your reference.

Thank you.

Ram Sun

Project Manager

ABC Technologies Pvt. Ltd.

↩ Reply

↪ Forward

😊

6. Inspect Sender Domain & Links

The sender's email address and embedded hyperlinks were carefully inspected to determine whether they belonged to the organization the email claimed to represent. A mismatch between the claimed organization and the actual domain is a common indicator of phishing.

Sample 1 – Fake Cloud Storage Account Verification

Claimed Organization: Cloud Storage Service

Expected Official Domain: cloudstorage.com (or the official domain of the cloud storage provider)

Observation: The sender domain does not match the official domain of the cloud storage service. The email also contains a suspicious verification link (drive-account-verify.com) that redirects users to an unofficial website designed to steal login credentials. The message creates urgency by warning that the account may be suspended if immediate action is not taken.

Result: High Risk – Possible Phishing Attempt

Sample 2 – Fake Payroll Email

Claimed Organization: Company Human Resources Department

Expected Official Domain: company.com

Observation: The sender uses an external domain instead of the organization's official domain (**company.com**). Employees should only receive payroll communications from the company's official email domain.

Result: Suspicious – Possible credential theft.

Sample 3 – Fake Package Delivery Email

Claimed Organization: Express Delivery Service

Expected Official Domain: expressdelivery.com (or the organization's official domain)

Observation: The sender domain differs from the legitimate delivery company's official domain. The email also asks the recipient to confirm their address using an external website, which is a common phishing technique.

Result: Suspicious – Possible phishing attempt.

Sample 4 – Legitimate Email

Claimed Organization: ABC Technologies Pvt. Ltd.

Expected Official Domain: company.com

Observation: The sender's email address matches the organization's official domain. The email contains normal business communication, does not request confidential information, and includes no suspicious links.

Result: Legitimate email.

7. Identify Phishing Indicators

The following phishing indicators were identified during the analysis:

- The sender's email domain does not match the organization it claims to represent.
- Generic greetings such as "Dear User" or "Dear Customer" are used instead of the recipient's name.
- The emails create urgency by threatening account suspension, delayed salary payments, or failed deliveries.
- Suspicious hyperlinks redirect users to unofficial websites.
- The emails request users to verify accounts or provide sensitive information.
- The messages attempt to create fear or panic to encourage immediate action.
- The sender domains imitate trusted organizations but are not official.

8. Classify Email Risk

Email Sample	Risk Level	Reason
Fake Cloud Storage Verification	High	Attempts to steal user credentials through a fake login page.
Fake Payroll Update	High	Requests sensitive employee information using a fake HR domain.
Fake Package Delivery	Medium	Uses social engineering to redirect users to a fake website.
Legitimate Project Meeting	Legitimate (Low Risk)	Official sender domain with normal business communication and no phishing indicators.

9. Document Findings

Based on the email analysis, three emails exhibited clear phishing characteristics, including spoofed sender domains, urgent language, suspicious hyperlinks, and requests for sensitive information. These emails were classified as Medium or High risk depending on their objective. The legitimate email originated from the organization's official domain, contained routine business communication, and showed no phishing indicators.

10. Prevention & Awareness Guidelines

To reduce the risk of phishing attacks, users should follow these security best practices:

- Always verify that the sender's email domain matches the official organization.
- Hover over hyperlinks to inspect the destination before clicking.
- Never share passwords, OTPs, or banking information through email.
- Be cautious of emails that create urgency or threaten immediate consequences.
- Avoid opening unexpected attachments or clicking unknown links.
- Confirm suspicious requests directly with the organization using official contact details.
- Enable Multi-Factor Authentication (MFA) for important accounts.
- Keep systems and antivirus software up to date.
- Report suspicious emails to the organization's IT or security team immediately.
- Participate in regular cybersecurity awareness training to recognize evolving phishing techniques.

Conclusion

This project demonstrated how phishing emails can be identified through email header analysis, sender domain verification, and inspection of phishing indicators. Three phishing emails and one legitimate email were analyzed and classified based on their level of risk. The findings showed that phishing attacks commonly use spoofed domains, urgent language, and suspicious links to deceive users. The project also emphasized the importance of verifying email authenticity and following cybersecurity best practices. Overall, user awareness combined with technical analysis is essential for preventing phishing attacks and protecting sensitive information.